

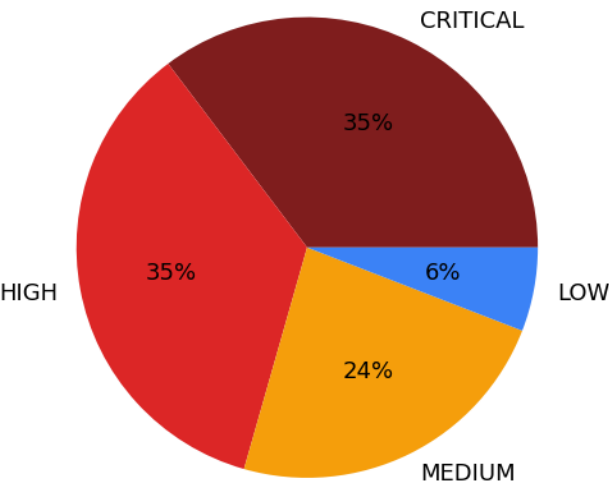
IoTSecureScan Assessment Report

IoTSecureScan Assessment

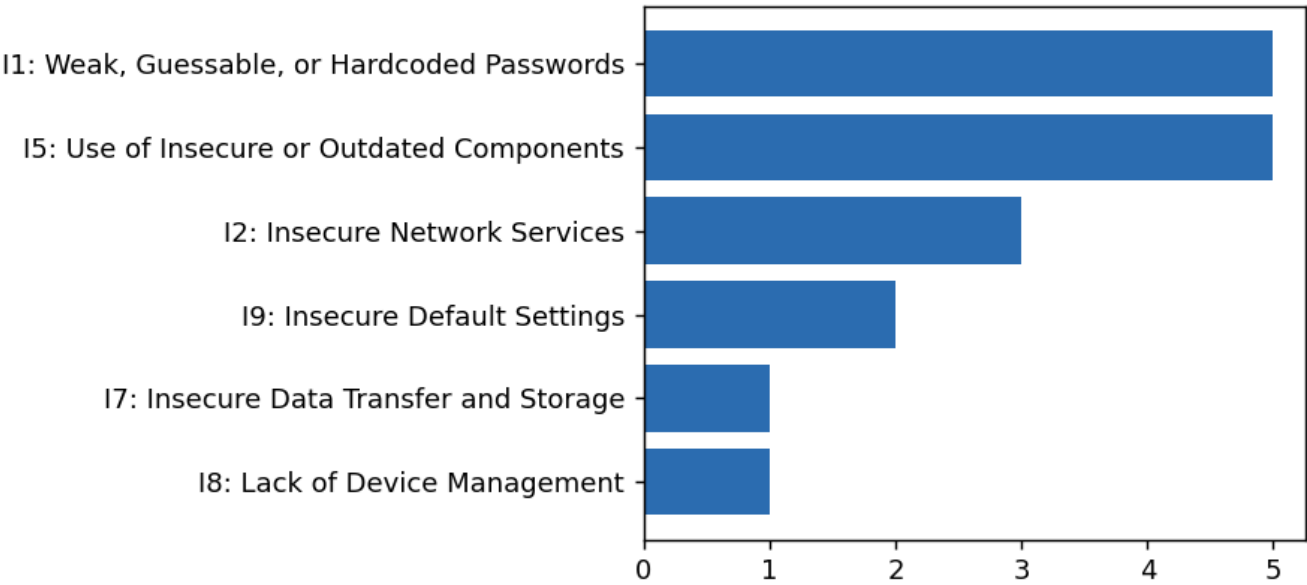
Generated 2026-07-07 01:31 UTC

Overall Risk Score: 95.0/100 (CRITICAL)

Findings by Severity



Findings by OWASP IoT Top 10 Category



Scope

Firmware analyzed: synthetic vulnerable firmware fixture (demo)

Network target: 127.0.0.1 (ports: 23,8080,1883)

Findings (17)

[CRITICAL] Embedded private key material

Module: SAST | Location: ./demo_firmware_fixture/etc/server.key

CWE: CWE-321 | OWASP IoT: I1: Weak, Guessable, or Hardcoded Passwords

A private key is embedded directly in the firmware image, typically shared across an entire product line.

Evidence: -----BEGIN RSA PRIVATE KEY----- MIIBOgIBAAJBAK

Recommendation: Provision a unique key per device via a hardware secure element; never ship a shared private key.

[CRITICAL] Hardcoded credential or secret

Module: SAST | Location: ./demo_firmware_fixture/bin/start_services.sh

CWE: CWE-798 | OWASP IoT: I1: Weak, Guessable, or Hardcoded Passwords

A hardcoded password, secret, or API key is embedded directly in firmware source/config.

Evidence: I /bin/sh & DB_PASSWORD="SuperSecret123!" CLOUD_API_KEY

Recommendation: Remove hardcoded secrets; provision unique per-device credentials via a secure element/HSM at manufacturing time.

[CRITICAL] Hardcoded credential or secret

Module: SAST | Location: ./demo_firmware_fixture/bin/start_services.sh

CWE: CWE-798 | OWASP IoT: I1: Weak, Guessable, or Hardcoded Passwords

A hardcoded password, secret, or API key is embedded directly in firmware source/config.

Evidence: ret123!" CLOUD_API_KEY="AKIAEXAMPLE1234567890" curl http://u

Recommendation: Remove hardcoded secrets; provision unique per-device credentials via a secure element/HSM at manufacturing time.

[CRITICAL] Heartbleed (CVE-2014-0160)

Module: FCA | Location: ./demo_firmware_fixture - OpenSSL 1.0.1f

CWE: CWE-125 | OWASP IoT: I5: Use of Insecure or Outdated Components

Bundled OpenSSL version is vulnerable to Heartbleed, allowing remote memory disclosure (private keys, credentials, session data).

Evidence: detected version 1.0.1f (< patched 1.0.1g)

Recommendation: Upgrade OpenSSL to a release newer than 1.0.1g.

[CRITICAL] Insecure/high-risk service exposed: Telnet (port 23)

Module: DAST | Location: 127.0.0.1:23

CWE: CWE-319 | OWASP IoT: I2: Insecure Network Services

Telnet transmits credentials/commands in cleartext and is the #1 IoT botnet (e.g. Mirai) entry point.

Evidence: BusyBox v1.19.4 (2014-01-01) built-in shell

IPCAM-DVR login:

Recommendation: Disable Telnet unless strictly required; otherwise restrict to an authenticated management VLAN.

[CRITICAL] Web admin panel advertises default credentials

Module: DAST | Location: 127.0.0.1:8080

CWE: CWE-1188 | OWASP IoT: I9: Insecure Default Settings

The device's web management interface response references default/shipped credentials.

Evidence: <html><h1>ip camera admin</h1>default login: admin / admin</html>

Recommendation: Force a credential change on first boot; never ship a working default account.

[HIGH] Telnet daemon enabled at boot

Module: SAST | Location: ./demo_firmware_fixture/bin/start_services.sh

CWE: CWE-319 | OWASP IoT: I2: Insecure Network Services

Firmware starts a telnet service, which transmits credentials and commands in cleartext.

Evidence: e debug access telnetd -l /bin/sh & D

Recommendation: Disable telnet; use SSH with key-based auth restricted to a management VLAN.

[HIGH] Memory-unsafe or command-injection-prone function

Module: SAST | Location: ./demo_firmware_fixture/bin/app.c

CWE: CWE-120 | OWASP IoT: I5: Use of Insecure or Outdated Components

Firmware source calls a function commonly associated with buffer overflows or command injection.

Evidence: r buf[64]; strcpy(buf, user_input

Recommendation: Replace with bounds-checked equivalents (strncpy/snprintf); never pass untrusted input to system().

[HIGH] Memory-unsafe or command-injection-prone function

Module: SAST | Location: ./demo_firmware_fixture/bin/app.c

CWE: CWE-120 | OWASP IoT: I5: Use of Insecure or Outdated Components

Firmware source calls a function commonly associated with buffer overflows or command injection.

Evidence: s check */ system(user_input);

Recommendation: Replace with bounds-checked equivalents (strncpy/snprintf); never pass untrusted input to system().

[HIGH] BusyBox wget command handling issue (CVE-2018-1000517)

Module: FCA | Location: ./demo_firmware_fixture - BusyBox 1.19.4

CWE: CWE-22 | OWASP IoT: I5: Use of Insecure or Outdated Components

Bundled BusyBox version is affected by a known wget-related file handling vulnerability.

Evidence: detected version 1.19.4 (< patched 1.28.0)

Recommendation: Upgrade BusyBox to a release newer than 1.28.0.

[HIGH] Dropbear SSH memory corruption (CVE-2016-7406)

Module: FCA | Location: ./demo_firmware_fixture - Dropbear SSH 2014.63

CWE: CWE-787 | OWASP IoT: I5: Use of Insecure or Outdated Components

Bundled Dropbear SSH version is affected by known memory-corruption vulnerabilities reachable pre-auth.

Evidence: detected version 2014.63 (< patched 2016.74)

Recommendation: Upgrade Dropbear SSH to a release newer than 2016.74.

[HIGH] Insecure/high-risk service exposed: MQTT (port 1883)

Module: DAST | Location: 127.0.0.1:1883

CWE: CWE-306 | OWASP IoT: I2: Insecure Network Services

MQTT broker reachable; if unauthenticated, any client can publish/subscribe to device topics.

Evidence: mqtt

Recommendation: Disable MQTT unless strictly required; otherwise restrict to an authenticated management VLAN.

[MEDIUM] Weak password hash format (MD5-crypt)

Module: SAST | Location: ./demo_firmware_fixture/etc/shadow

CWE: CWE-916 | OWASP IoT: I1: Weak, Guessable, or Hardcoded Passwords

Password hashes use the legacy MD5-crypt (\$1\$) format, which is fast to brute-force offline.

Evidence: root:\$1\$abcd\$K3xamplEwe

Recommendation: Use bcrypt/scrypt/argon2 with a per-user salt for credential storage.

[MEDIUM] Weak password hash format (MD5-crypt)

Module: SAST | Location: ./demo_firmware_fixture/etc/passwd

CWE: CWE-916 | OWASP IoT: I1: Weak, Guessable, or Hardcoded Passwords

Password hashes use the legacy MD5-crypt (\$1\$) format, which is fast to brute-force offline.

Evidence: ./bin/sh admin:\$1\$4Uf/\$H0nQe1Exam

Recommendation: Use bcrypt/scrypt/argon2 with a per-user salt for credential storage.

[MEDIUM] Cleartext HTTP endpoint referenced

Module: SAST | Location: ./demo_firmware_fixture/bin/start_services.sh

CWE: CWE-319 | OWASP IoT: I7: Insecure Data Transfer and Storage

Firmware communicates with a remote endpoint (e.g. update server) over unencrypted HTTP.

Evidence: 34567890" curl http://update.example.com/fw_latest.bin -o /tmp/fw.bin

Recommendation: Use HTTPS/TLS with certificate pinning for firmware update and telemetry channels.

[MEDIUM] World-writable file in firmware image

Module: SAST | Location: ./demo_firmware_fixture/bin/start_services.sh

CWE: CWE-732 | OWASP IoT: I9: Insecure Default Settings

File is world-writable, allowing any local process/user to modify it.

Recommendation: Restrict permissions to least privilege (e.g. 0644/0755).

[LOW] Open network service: BaseHTTPServer (port 8080)

Module: DAST | Location: 127.0.0.1:8080

CWE: CWE-1059 | OWASP IoT: I8: Lack of Device Management

Service BaseHTTPServer 0.6 is reachable over the network.

Recommendation: Confirm this service is required and reachable only from authorized management hosts.

Appendix: OWASP IoT Top 10 Reference

I1: Weak, Guessable, or Hardcoded Passwords

I2: Insecure Network Services

I3: Insecure Ecosystem Interfaces

I4: Lack of Secure Update Mechanism

I5: Use of Insecure or Outdated Components

I6: Insufficient Privacy Protection

I7: Insecure Data Transfer and Storage

I8: Lack of Device Management

I9: Insecure Default Settings

I10: Lack of Physical Hardening